



Detailed Project Case Study: The Sentinel Hybrid-SOC

Subtitle: Engineering an Automated Detection & Response Ecosystem for Hybrid-Cloud Environments

1. Vision & Strategic Objective

The **Sentinel Hybrid-SOC** project was conceptualized to solve a critical modern security challenge: fragmented visibility and latent response times in hybrid environments. Moving beyond textbook definitions, my objective was to engineer a fully operational Security Operations Center (SOC) within a virtualized lab.

This project was designed to simulate a real-world enterprise network, integrating **on-premise endpoints** (Windows 10) with **public cloud infrastructure** (AWS). The core investigative goal was to map sophisticated attack chains—such as **Ransomware simulation** and **Cloud Credential theft**—to the **MITRE ATT&CK** framework, creating a high-fidelity detection engine.

2. Technical Architecture & Structural Design

I architected a tiered security stack built on a foundation of **Oracle VirtualBox**, utilizing industry-standard, open-source, and free-tier tools to create a professional-grade defense system.

2.1. The Structural Components (The "Bones"):

- Type 2 Hypervisor: **VirtualBox** providing safe, network-isolated "sandboxes" for destructive attack testing.
- **The SIEM/EDR "Brain" (Wazuh):** I deployed the **Wazuh Manager** (running on Ubuntu Server) as the central nervous system. I chose Wazuh for its integrated File Integrity Monitoring (FIM), Vulnerability Assessment, and active-response capabilities.

- **The On-Premise Target (Windows 10):** A **Wazuh Agent** was deployed on a Windows 10 VM. To maximize granular visibility, I installed **Sysmon** using the **SwiftOnSecurity** configuration, enabling deep inspection of process creation (Event ID 1), network connections (Event ID 3), and file modification events.
- **The Cloud Environment (AWS Free Tier):** A modern security setup requires cloud visibility. I configured **AWS CloudTrail** to log all account-level API activity and enabled **AWS GuardDuty** for intelligent threat detection.

- **The Automation Engine (Shuffle SOAR):** A crucial addition for 2026 workflows, **Shuffle SOAR** was deployed (via Docker) to act as the "muscle" of the operation, automating the decision-making and containment logic.

3. Operational Logic & The Investigation (The "Nerves")

This is where my **Investigative Mindset** was applied. The project followed a rigid logical algorithm for all threat scenarios.

3.1. Data Ingestion & Normalization Flow:

1. **Endpoint Telemetry:** **Sysmon** enriches Windows Event logs → **Wazuh Agent** parses logs in real-time → Data is encrypted and sent over a **Bridged Network** adapter to the Manager.

2. Cloud Telemetry: AWS

CloudTrail → S3 Bucket → **Wazuh Manager** polls the S3 bucket every 5 minutes (via IAM-secured credentials), ingesting all cloud audit logs.

3.2. Threat Simulation Scenario: Ransomware Behavior:

To test the system, I executed a controlled attack simulation using **Atomic Red Team** scripts that mimicked typical **Ransomware behavior** (Tactic: **TA0040 Impact**, Technique: **T1486 Data Encrypted for Impact**).

- **The Attack:** The script initiated rapid file modifications and deletions in a targeted directory on the Windows VM.

- **The Triage (Wazuh):** My investigation focused on configuring **Wazuh's FIM (File Integrity Monitoring)** module. The system immediately picked up the high-frequency file changes. Wazuh's correlation engine generated a **Severity 12 (Critical)** alert: *"Ransomware-like file modification behavior detected."*
- **The Automation Trigger:** This critical alert automatically triggered a custom **Webhook** call to my pre-configured **Shuffle SOAR** workflow, initiating the containment algorithm.

3.3. Threat Simulation Scenario: Cloud Credential Theft:

I simulated an adversary who had stolen a company's AWS API keys and was using a tool like **Stratus Red Team** to conduct reconnaissance (Tactic: **TA0007 Discovery**).

- **The Attack:** The attacker executed multiple `GetSecretValue` calls from a non-company IP address, attempting to harvest secrets from AWS Secrets Manager.
- **The Triage (Wazuh): AWS CloudTrail** logged the API calls. My Wazuh SIEM was configured with specific **anomaly detection rules** to flag rapid, bulk retrieval of secrets. This triggered a high-severity alert in the Wazuh console.

4. The "Capstone": Automated Active Response (The "Brain")

The most significant achievement of this project was engineering a low-latency, automated **Active Response** to contain critical threats.

4.1. The Automated Containment Workflow (Shuffle):

When Shuffle SOAR received the "Ransomware-like behavior" alert (Scenario 3.2), it executed a tiered logic workflow I architected:

1. **Enrichment (The Investigation):**
Shuffle extracted the malicious file's **MD5 hash** (from Sysmon) and queried the **VirusTotal API**.
2. **Decision Logic: IF** the hash was flagged as malicious (score >1) **AND** the SIEM alert severity was critical, **THEN** initiate containment.

3. **Active Response (The Containment):** Shuffle sent an **API command** back to the Wazuh Manager. The Wazuh Manager utilized its unique "**Active Response**" module to send a command to the target Windows Agent.
4. **The Result:** The Agent instantly executed a built-in script, configuring the local Windows Firewall to **block ALL network traffic** from the infected machine *except* for communication with the Wazuh Manager.
5. **Output:** A critical notification was automatically sent to my Discord channel: *"Host ISOLATED on Ransomware Simulation. Incident ID 12345. Review Timeline."*

4.2. Forensic Validation (Network Traffic Analysis):

To validate the attack chain and containment, I used **Wireshark** to capture packets on the local network during a **Reverse Shell** simulation. My investigation focused on identifying the **TCP three-way handshake** and the C2 (Command and Control) traffic. These network artifacts were captured as screenshots and included in the final **Incident Timeline** of my professional report, providing definitive forensic proof of the attack.

5. Project Outcomes & Business Value

The **Sentinel Hybrid-SOC** project produced a series of professional-grade deliverables that simulate real-world SOC artifacts:

- **Visibility Verified:** Centralized monitoring of heterogeneous systems (Windows & AWS) from a single "pane of glass."
- **Strategic Mapping:** All detections mapped to the **MITRE ATT&CK** dashboard in Wazuh, proving framework familiarity.
- **Documented Victory:** A 10-page **Professional Incident Report (PDF)**, including an architecture diagram (Draw.io), a detailed incident timeline, forensic artifacts, and mitigation recommendations.

- **Measurable Success:** The automated isolation workflow successfully contained the threat within **15 seconds** of detection, demonstrating a significant reduction in **Mean Time to Respond (MTTR)**.

6. Critical Challenges & Resolutions (Problem Solving)

An employer wants to know how you handle failure. My project journey included several key technical hurdles:

- **The Problem:** The Wazuh Agent on Windows was installed, but the status remained "Disconnected" in the manager's dashboard.

- **The Investigation:** My investigative focus was on connectivity. I used `ping` and `telnet` from the Windows VM to the Wazuh Manager IP. Telnet to port `1514` (the data port) failed, indicating a block.
- **The Resolution:** The problem was the **Wazuh Manager's Ubuntu Firewall (UFW)**. I logged into the manager and executed `sudo ufw allow 1514/tcp`. The connection was instantly established, and the agent showed "Active."

This project journey was a constant "puzzle" that solidified my investigative, architectural, and problem-solving abilities. It proves that I can not only use security tools but can also architect, automate, and defend an infrastructure to protect an organization's critical assets.